

CoreAxis Technologies

Information Security Department Handbook

1. Welcome to the Information Security Department

1.1 Message from the CISO

Welcome to the Information Security Department at CoreAxis Technologies. This handbook serves as the definitive reference for all security professionals operating within or alongside the Information Security function.

CoreAxis Technologies develops AI-powered enterprise software, Retrieval-Augmented Generation (RAG) systems, Large Language Model (LLM) applications, and cloud-native platforms. The nature of our business places us at the intersection of two domains where security is non-negotiable: enterprise software and artificial intelligence. Our clients trust us with sensitive business processes and proprietary data. Our obligation to protect that trust is absolute.

This handbook defines how the Information Security department operates — our governance structures, our policies, our procedures, and our standards. Every member of this department is expected to know this document, operate within its guidelines, and contribute to its continuous improvement.

Security at CoreAxis is not a function of compliance checklists. It is a discipline embedded in how we build, how we operate, and how we respond to adversity. The threat landscape we face is sophisticated and evolving. Our response must be equally so.

1.2 Scope and Applicability

This handbook applies to all members of the Information Security department across both the Chennai (Head Office) and Bengaluru (Branch Office) locations. Relevant sections also apply to employees in other departments insofar as they interact with security systems, processes, or obligations.

The handbook governs the protection of:

- Corporate IT infrastructure and endpoints
- Cloud environments hosted on AWS and Azure
- Application code and CI/CD pipelines
- AI models, datasets, embedding vectors, and RAG pipelines
- Client data and contractual data obligations
- Employee identities and access rights
- All data classified as Confidential, Restricted, or Internal per the CoreAxis Information Classification Policy

This is a living document. All security personnel are responsible for flagging outdated content. The CISO will review and formally publish updated versions on a quarterly basis.

2. Department Overview

2.1 Mission of the Information Security Department

The Information Security department exists to protect CoreAxis Technologies' information assets, infrastructure, and intellectual property from unauthorized access, misuse, disruption, modification, or destruction. We enable the business to operate securely at scale by providing governance, engineering controls, operational monitoring, and strategic security guidance.

Our mandate covers the full information security lifecycle: risk identification, control design, implementation, monitoring, incident response, and continuous improvement. We operate under a Zero Trust Architecture philosophy and apply Defense in Depth across all technology layers.

2.2 Department Objectives

The Information Security department is accountable for the following outcomes:

1. Maintaining the confidentiality, integrity, and availability of all CoreAxis information assets.

2. Ensuring all production systems meet defined security baselines before deployment.
3. Responding to security incidents within defined SLA thresholds.
4. Maintaining compliance with applicable regulatory frameworks, including ISO/IEC 27001 and SOC 2 Type II trust service criteria.
5. Delivering mandatory security awareness training to all employees on an annual basis.
6. Conducting quarterly internal security audits and annual penetration testing exercises.
7. Managing the full lifecycle of third-party vendor security assessments.
8. Providing security guidance and review for all AI products under development.

2.3 Working Model and Availability

The Information Security department operates on a hybrid model. Engineers and analysts maintain physical presence at the Chennai Head Office a minimum of three days per week. The Bengaluru Branch Office operates under the same hybrid requirements with local security personnel coordinating with the central team.

Standard working hours are Monday through Friday, 09:00 to 17:00 IST. The Security Operations Center (SOC) maintains an escalation-on-call rotation outside of core hours for Severity 1 and Severity 2 incidents. All security personnel are required to be reachable via mobile and enterprise communication platforms during on-call rotations.

Security incidents do not follow business hours. Incident responders are expected to mobilize within 30 minutes of a critical page regardless of time of day.

3. Security Team Structure

3.1 Chief Information Security Officer (CISO)

The CISO holds executive accountability for the information security posture of CoreAxis Technologies. The CISO reports directly to the Chief Executive Officer and maintains a dotted-line reporting relationship with the Board of Directors for risk and compliance matters.

Responsibilities include: setting the enterprise security strategy; owning the Information Security Policy and governance framework; representing security risk to executive leadership; overseeing regulatory compliance obligations; approving the annual security budget; and signing off on security exceptions above a defined risk threshold.

The CISO chairs the Security Governance Committee, which meets monthly and includes representation from HR, Legal, Finance, IT, and Engineering leadership.

3.2 Security Manager

The Security Manager is responsible for the day-to-day operations of the Information Security department. This role bridges strategy and execution —

translating CISO-level directives into actionable programs and managing the delivery of security initiatives across all technical and compliance domains.

Responsibilities include: managing the security team's workload and priorities; conducting performance reviews for all direct reports; tracking KPIs for operational security programs; coordinating cross-departmental security initiatives; managing the vendor security assessment program; and serving as the primary escalation point for the SOC outside of Severity 1 incidents.

3.3 Security Engineer

Security Engineers design and implement the technical controls that protect CoreAxis infrastructure, applications, and data. They work closely with IT and Engineering to embed security into systems architecture and software delivery pipelines.

Responsibilities include: designing and deploying security controls across cloud, network, and endpoint layers; conducting architecture reviews for new systems; leading vulnerability assessments and remediation programs; implementing SIEM configurations, alerting rules, and detection logic; managing secrets management platforms; and maintaining security tooling (endpoint protection, firewall policies, DLP).

3.4 Security Analyst

Security Analysts support the monitoring, investigation, and documentation functions of the Information Security department. They operate as the analytical layer between raw telemetry and actionable intelligence.

Responsibilities include: triaging security alerts from Splunk, Microsoft Sentinel, and ELK Stack; conducting log analysis and threat hunting; supporting incident

response investigations; maintaining documentation for security events and findings; performing compliance evidence collection; and supporting risk assessments through data analysis.

3.5 Cloud Security Engineer

Cloud Security Engineers are responsible for the security posture of CoreAxis cloud environments across AWS and Azure. They specialize in cloud-native security controls and ensure that infrastructure deployments conform to defined security baselines.

Responsibilities include: managing AWS IAM policies, roles, and permission boundaries; configuring and monitoring AWS GuardDuty, Security Hub, and AWS Config; managing Azure Security Center and Microsoft Defender for Cloud configurations; enforcing cloud security baselines using Infrastructure as Code (IaC) templates; reviewing cloud architecture designs; responding to cloud-specific security alerts; and conducting cloud misconfiguration assessments.

3.6 DevSecOps Engineer

DevSecOps Engineers integrate security into the software development lifecycle. They build and maintain the security tooling embedded in CI/CD pipelines and ensure that code cannot reach production without passing defined security gates.

Responsibilities include: maintaining GitHub Advanced Security configurations including secret scanning and code scanning; managing SonarQube quality gates and security rule sets; integrating OWASP Dependency-Check into build pipelines; designing and enforcing pre-merge security checks; supporting secure container image management in Docker and Kubernetes environments;

conducting threat modeling sessions with engineering teams; and supporting the Security Champion program across development teams.

3.7 Security Operations Center (SOC) Analyst

SOC Analysts form the operational detection and response function of the Information Security department. They monitor the threat landscape across CoreAxis environments in near-real-time and respond to alerts within defined SLA windows.

Responsibilities include: monitoring SIEM dashboards (Splunk, Microsoft Sentinel) for anomalous activity; triaging and classifying security alerts; executing Level 1 incident response actions per documented playbooks; escalating confirmed incidents to Security Engineers or the Security Manager; maintaining detailed records of all security events in the incident management platform; and participating in on-call rotations for after-hours coverage.

4. Information Security Governance

4.1 Governance Framework

CoreAxis Technologies operates its Information Security governance program in alignment with the ISO/IEC 27001 Information Security Management System

(ISMS) framework. The governance structure defines accountability, authority, and decision-making for all security-related matters.

The Security Governance Committee meets monthly and is chaired by the CISO. Membership includes the Security Manager, department heads from HR, Finance, IT, and Engineering, and the Legal counsel. Committee responsibilities include: reviewing and approving changes to security policy; tracking risk register status; reviewing audit findings; approving exceptions to security controls; and escalating material risk to the Board of Directors.

All security policies are reviewed annually at a minimum. Material changes to regulatory requirements, threat landscape conditions, or business operations may trigger an out-of-cycle review.

4.2 Policy Hierarchy

The CoreAxis security documentation hierarchy is structured as follows:

Level 1 — Information Security Policy (approved by CISO and Board): Establishes overarching principles, obligations, and accountability. This is the master policy from which all others derive authority.

Level 2 — Domain Policies (approved by CISO): Govern specific security domains such as Access Control, Data Classification, Incident Response, and Acceptable Use. Each policy in this handbook constitutes a Level 2 document.

Level 3 — Standards and Baselines (approved by Security Manager): Define specific technical requirements (e.g., password complexity, encryption algorithms, firewall rule standards).

Level 4 — Procedures and Playbooks (maintained by Security Engineers and SOC leads): Provide step-by-step operational guidance for executing security tasks and responding to incidents.

Exceptions to Level 1 or Level 2 policies require CISO approval and must be logged in the exceptions register with a defined remediation timeline.

4.3 Risk Management Integration

Security governance at CoreAxis is risk-driven. The Information Security department maintains a formal risk register that is reviewed quarterly by the Security Governance Committee and annually by the Board of Directors.

Risks are assessed using a likelihood-impact matrix scored 1–5 on each axis. The resulting risk score determines treatment priority:

- Critical (Score 20–25): Immediate remediation required; CISO escalation mandatory
- High (Score 12–19): Remediation within 30 days; Security Manager accountability
- Medium (Score 6–11): Remediation within 90 days; tracked in project backlog
- Low (Score 1–5): Accepted or monitored; reviewed at next quarterly cycle

All risk treatment decisions are documented with rationale, treatment owner, and target remediation date.

5. Security Policies

Acceptable Use Policy

CoreAxis IT assets — including endpoints, cloud environments, network infrastructure, and communication platforms — are provided for business use. Incidental personal use is permitted provided it does not interfere with business operations or expose company assets to risk.

Prohibited uses include: accessing, storing, or transmitting illegal content; exfiltrating proprietary or client data to unauthorized systems; installing unauthorized software on corporate devices; using corporate credentials on personal or unapproved applications; circumventing security controls including MFA, endpoint protection, or VPN; and conducting any activity that would constitute a violation of applicable law.

Violations of the Acceptable Use Policy are subject to disciplinary action up to and including termination of employment. Severe violations may result in referral to law enforcement authorities.

5.1 Clean Desk and Screen Lock Policy

All employees operating from CoreAxis office locations are required to maintain a clean desk when away from their workstation. This applies to printed documents, physical access tokens, handwritten notes containing sensitive information, and any media containing company data.

Screen lock must engage automatically after a maximum of five minutes of inactivity on all endpoints. Employees must lock their screens manually when leaving their desks for any duration. The keyboard shortcut for screen lock must be known by all users (Windows: Win+L; macOS: Ctrl+Cmd+Q).

Sensitive printed documents must not be left unattended at printers or on desks. Documents containing Confidential or Restricted information must be shredded when no longer needed using cross-cut shredders provided at both office locations.

5.2 Physical Security Policy

Access to CoreAxis office premises is controlled via electronic badge access systems. All employees are issued a unique access badge upon joining. Visitors must register at reception, present valid identification, and be escorted by a CoreAxis employee for the duration of their visit. Visitor logs are maintained and reviewed weekly.

Tailgating through access-controlled doors is prohibited. Employees must not permit entry to individuals whose identity they cannot verify. Suspected unauthorized access must be reported to the Security Manager immediately.

Server rooms, network equipment rooms, and any infrastructure hosting areas are classified as restricted zones. Access to restricted zones requires prior authorization from the Security Manager and is logged electronically.

Contractors accessing restricted zones must be accompanied by an authorized CoreAxis employee.

6. Risk Assessment Process

6.1 Risk Assessment Methodology

CoreAxis conducts risk assessments using a structured methodology aligned with ISO/IEC 27005. Assessments are conducted at the following intervals and trigger points:

Scheduled assessments:

- Annual enterprise-wide risk assessment covering all information assets
- Quarterly review and update of the risk register
- Bi-annual departmental risk reviews

Event-driven assessments:

- Introduction of new systems, services, or cloud infrastructure
- Significant changes to existing systems or processes
- Post-incident risk reviews following confirmed security incidents
- New client onboarding involving sensitive data processing

Each assessment follows four phases: asset identification and scoping; threat identification; vulnerability identification; and risk evaluation. Results are recorded in the centralized risk register maintained by the Security Manager.

6.2 Risk Treatment Options

Following assessment, each identified risk is assigned one of four treatment options:

Mitigate: Implement controls to reduce the likelihood or impact of the risk to an acceptable level. This is the default treatment for High and Critical risks.

Transfer: Transfer the financial consequence of the risk through cyber insurance or contractual liability clauses with vendors. Appropriate for risks where residual impact can be monetized.

Avoid: Discontinue the activity or system that gives rise to the risk where the business value does not justify the residual exposure.

Accept: Formally document that the risk is acknowledged and no further treatment is warranted at this time. Acceptance of any risk scored Medium or above requires CISO sign-off and must be reviewed at the next quarterly cycle.

All accepted risks must be logged in the risk register with a rationale statement, the name of the accepting authority, and a review date.

7. Information Classification

7.1 Classification Levels

All information created, received, or processed by CoreAxis Technologies must be classified into one of the following levels:

PUBLIC: Information that may be freely shared externally without restriction. Examples include marketing materials, published press releases, and open-source documentation.

INTERNAL: Information intended for general internal use within CoreAxis. Not for external distribution without approval. Examples include internal announcements, general operational procedures, and non-sensitive internal communications.

CONFIDENTIAL: Information whose unauthorized disclosure would harm CoreAxis, its clients, or its employees. Examples include client contracts, employee performance reviews, unreleased product specifications, and financial projections. Access is limited to employees with a legitimate business need.

RESTRICTED: The most sensitive classification, reserved for information whose unauthorized disclosure would cause severe harm. Examples include AI model weights, client PII, cryptographic keys, security audit findings, and board-level deliberations. Access requires explicit authorization from the information owner and the Security Manager.

7.2 Classification Responsibilities

The creator or owner of a document or dataset is responsible for assigning the appropriate classification at the time of creation. If classification is unclear, the default is CONFIDENTIAL pending review by the Security Manager.

Classification must be displayed on all documents through a header or footer marking. Digital files must include classification metadata where the system

supports it. Emails containing CONFIDENTIAL or RESTRICTED information must include the classification in the subject line.

Reclassification may only be performed by the information owner or, in their absence, their designated manager. Downward reclassification (e.g., from RESTRICTED to CONFIDENTIAL) requires Security Manager approval and must be logged.

8. Data Handling Standards

8.1 Data at Rest

All CONFIDENTIAL and RESTRICTED data stored on CoreAxis systems must be encrypted at rest using AES-256 or equivalent. This requirement applies to:

- Data stored on corporate endpoints (enforced via BitLocker on Windows devices)
- Data stored in cloud storage services (AWS S3 with SSE-S3 or SSE-KMS; Azure Blob Storage with Azure-managed or customer-managed keys)
- Database contents (column-level encryption required for fields classified as RESTRICTED)
- Backup media and archive storage

Unencrypted storage of CONFIDENTIAL or RESTRICTED data on portable media (USB drives, external hard drives) is prohibited. Where portable media is

operationally required, it must be encrypted and its use must be authorized by the Security Manager.

8.2 Data in Transit

All CONFIDENTIAL and RESTRICTED data transmitted over any network — internal or external — must be encrypted in transit. Minimum requirements:

- TLS 1.2 is the minimum acceptable protocol; TLS 1.3 is preferred for all new implementations
- TLS 1.0 and TLS 1.1 are deprecated and must not be used
- Certificate validation must be enforced; self-signed certificates are not permitted in production environments
- API communications carrying CONFIDENTIAL or RESTRICTED data must use mutual TLS (mTLS) where technically feasible
- VPN connections using approved protocols (WireGuard or IKEv2/IPsec) are required for remote access to internal networks

Plain-text protocols (HTTP, FTP, Telnet, unencrypted SMTP) are prohibited for any production or business-critical data transmission.

8.3 Data Disposal

When CONFIDENTIAL or RESTRICTED data is no longer required, it must be disposed of in a manner that renders recovery infeasible.

Digital data disposal requirements:

- Logical deletion is insufficient for RESTRICTED data; cryptographic erasure (key destruction) or multi-pass overwrite (NIST SP 800-88 guidelines) is required
- Decommissioned storage devices must be processed by the IT team using

approved tools before disposal or repurposing

- Cloud storage bucket deletions must include verification that object versioning and cross-region replication are also cleared

Physical data disposal requirements:

- Printed documents classified CONFIDENTIAL or RESTRICTED must be shredded using cross-cut or micro-cut shredders
- Physical storage media (HDDs, SSDs, optical media) must be physically destroyed or processed by a certified data destruction vendor with a destruction certificate provided
- Destruction records must be retained for three years

9. Identity and Access Management (IAM)

9.1 IAM Architecture

CoreAxis Technologies operates a centralized identity management architecture anchored on Microsoft Entra ID (formerly Azure AD) as the primary identity provider. All enterprise user identities are provisioned through and governed by Entra ID.

Okta is deployed as a secondary identity broker for SaaS application integrations where Entra ID federation is not natively supported. LDAP is used for legacy on-premises systems integration where required.

Active Directory is maintained for on-premises domain authentication at both office locations and synchronizes with Entra ID via Microsoft Entra Connect. The canonical source of identity truth for all employees is the HR system; provisioning workflows are triggered by HR events (onboarding, role changes, offboarding).

All user access — including privileged access — is governed under the principle of least privilege. No access is granted beyond the minimum required to perform a defined business function.

9.2 Identity Lifecycle Management

The identity lifecycle at CoreAxis follows four phases: Provision, Maintain, Review, and Deprovision.

Provision: New employee accounts are created within 24 hours of the confirmed start date. Accounts are provisioned with baseline access defined by the employee's role profile. Access beyond the baseline requires formal approval from the requesting manager and the relevant system owner.

Maintain: Changes to access (role changes, project assignments, relocations) are processed within two business days of a formal request through the access request system.

Review: Quarterly access reviews are conducted for all CONFIDENTIAL and RESTRICTED systems. Reviewers are the system owners and department managers. Access not reaffirmed within the review window is automatically revoked.

Deprovision: All accounts — corporate directory, application, cloud, VPN — must be disabled within two hours of confirmed departure notification and fully deleted within 30 days. Shared account credentials to which the departing employee had access must be rotated immediately upon departure.

10. Role-Based Access Control (RBAC)

10.1 RBAC Principles

CoreAxis implements Role-Based Access Control across all enterprise systems. Access rights are assigned to roles rather than directly to individuals. Users are assigned one or more roles based on their job function. No user is assigned more access than their defined role requires.

Standard roles are defined for each department and system by the Security Manager in consultation with department heads. Custom roles require Security Manager approval. Roles are reviewed annually and any time a significant change to a system or business process occurs.

The Separation of Duties (SoD) principle is enforced for sensitive operations. No single role should permit a user to both initiate and approve a sensitive transaction (e.g., creating and approving a financial transfer; requesting and approving their own access).

10.2 Cloud IAM Roles

AWS IAM roles follow the principle of least privilege. Service accounts and Lambda functions are assigned IAM roles with the minimum permissions required for their specific function. Inline policies are discouraged; managed policies with clear ownership are preferred.

Permission boundaries are applied to all developer-created IAM roles to prevent privilege escalation. AWS Organizations Service Control Policies (SCPs) define the maximum permissions available in each account. Security team members have read-only access to production AWS accounts by default; write access requires a time-limited session approval workflow.

Azure RBAC follows the same principles. Azure roles are assigned at the resource group or subscription level with built-in roles preferred over custom definitions. Azure PIM (Privileged Identity Management) is used to gate just-in-time elevation for privileged Azure roles.

11. Password Policy

11.1 Password Requirements

All user-created passwords for CoreAxis systems must meet the following requirements:

Minimum length: 14 characters

Complexity: Must include at least one uppercase letter, one lowercase letter, one number, and one special character

Prohibited: Passwords that appear in known breach lists (HaveIBeenPwned integration); passwords containing the user's name, username, or department name; sequential or repeated characters (e.g., "aaaaaa", "123456")

Privileged accounts (administrator, root, service accounts with elevated permissions): Minimum 20 characters, randomly generated, stored in the approved secrets manager.

Password rotation:

- Standard user accounts: No mandatory rotation unless compromise is suspected (aligned with NIST SP 800-63B guidance; rotation fatigue increases vulnerability)
- Privileged accounts: Rotation every 90 days or immediately upon any suspected compromise
- Service accounts: Rotation every 180 days via automated secrets management workflow

Reuse: Last 12 passwords may not be reused.

11.2 Password Manager Requirements

All employees are required to use the enterprise-approved password manager for storage of all corporate credentials. Personal password managers may not be used to store CoreAxis credentials.

The approved password manager is provisioned through Entra ID and enforces vault encryption, MFA access, and audit logging of vault access events. Passwords must not be stored in browsers, plain-text files, spreadsheets, or note-taking applications.

Sharing of credentials between employees is prohibited with the exception of shared service accounts, which must be managed exclusively through the password manager's shared vault feature with individual audit trails maintained.

12. Multi-Factor Authentication (MFA)

12.1 MFA Requirements

Multi-Factor Authentication is mandatory for all CoreAxis user accounts accessing corporate systems. There are no exceptions to this requirement. MFA must be enrolled before any user account is granted access to production systems or sensitive data.

Approved second factors in order of preference:

1. Hardware security keys (FIDO2/WebAuthn) — Required for privileged accounts
2. Authenticator application (Microsoft Authenticator, Google Authenticator, Authy) — Standard for all users
3. Push notification via Microsoft Authenticator — Acceptable where TOTP is not possible

Prohibited second factors:

- SMS-based OTP (phishing and SIM-swap risk; not acceptable for any account)
- Email-based OTP (same channel as primary credential, insufficient separation)
- Security questions

MFA is enforced by Entra ID Conditional Access policies. Any access attempt that does not satisfy MFA is blocked regardless of credential validity.

12.2 Phishing-Resistant MFA

For privileged users — CISO, Security Engineers, Cloud Security Engineers, DevSecOps Engineers, and IT Administrators — phishing-resistant MFA using hardware security keys (FIDO2/WebAuthn) is mandatory. This requirement is enforced via Entra ID Conditional Access policy targeting privileged role assignments.

FIDO2 hardware tokens (YubiKey or equivalent) are issued to all privileged users by the IT department. Loss or theft of a hardware token must be reported immediately to the Security Manager. The lost token must be de-registered before a replacement is issued.

Regular MFA bypass attempts (e.g., MFA fatigue attacks, SIM swapping against individual accounts) are treated as security incidents and trigger SOC investigation protocols.

13. Privileged Access Management

13.1 Privileged Access Standards

Privileged access — including local administrator rights, domain administrator accounts, root access to servers, and cloud administrative roles — is governed by a dedicated Privileged Access Management (PAM) program.

All privileged sessions must be conducted through approved PAM tooling that provides: session recording and audit logging; just-in-time (JIT) access with time-limited sessions; credential vaulting for service accounts; and anomaly detection on privileged session activity.

Standing privileged access is prohibited for production environments.

Production administrative access must be requested, approved by the Security Manager or CISO, and time-limited to the duration required for the specific task. Access is granted via AWS IAM Identity Center sessions or Azure PIM activations, both of which enforce session duration limits and generate audit trails.

Privileged accounts must not be used for day-to-day activities such as email, web browsing, or document editing. Privileged users must maintain separate standard accounts for non-administrative tasks.

13.2 Service Account Management

Service accounts are non-human identities used by applications, automation scripts, and integration services. They are subject to the following controls:

- Each service account must have a documented owner (person and department)
- Service accounts must be granted only the permissions required for their specific technical function
- Service account credentials must be stored in the approved secrets management platform (AWS Secrets Manager, Azure Key Vault, or HashiCorp Vault where applicable)
- Service account passwords must be rotated every 180 days via automated workflows; rotation must not require application downtime
- Service accounts must not have interactive login enabled unless operationally required and explicitly approved
- Unused or dormant service accounts must be disabled within 30 days of last use and removed within 90 days

Quarterly reviews of all service account permissions are conducted by the Security Engineer with sign-off from respective system owners.

14. Endpoint Security

14.1 Endpoint Security Standards

All corporate endpoints — laptops, desktops, and mobile devices — must meet defined security standards before connecting to any CoreAxis network or accessing corporate resources. Endpoints that do not satisfy compliance checks are quarantined until remediated.

Mandatory controls for all managed endpoints:

- Endpoint Detection and Response (EDR): Microsoft Defender for Endpoint is deployed on all Windows devices. CrowdStrike Falcon is deployed on macOS devices. Both are centrally managed and must not be disabled by end users.
- Full-disk encryption: BitLocker (Windows) or FileVault (macOS) enabled with recovery keys escrowed to the central key management system
- Automatic OS and application updates enabled with a maximum 14-day patch lag for critical vulnerabilities
- Endpoint firewall enabled at all times
- Local administrator rights restricted; standard users operate without local admin; elevated tasks require IT approval and are time-limited
- USB mass storage devices blocked by policy except for approved, encrypted devices

Corporate-owned mobile devices must be enrolled in Microsoft Intune for Mobile Device Management (MDM). Personal devices accessing corporate email or

applications must enroll in the MDM Mobile Application Management (MAM) profile.

15. Device Security Standards

Device Procurement and Configuration

All devices used to access CoreAxis systems must be procured through the IT department or explicitly approved by IT prior to purchase. Consumer-grade devices are not approved for CONFIDENTIAL or RESTRICTED data access.

Device configuration standards:

- BIOS/UEFI password protection enabled
- Secure Boot enabled on all Windows endpoints
- OS configured to the CIS Benchmark hardening baseline for the respective platform
- Only approved application list permitted; application whitelisting enforced via Defender Application Control (Windows) or endpoint management policy (macOS)
- Screen lock enforced after 5 minutes maximum inactivity via MDM policy; overriding this setting by end users is blocked

Device loss or theft must be reported to IT and the Security Manager within two hours. Remote wipe will be initiated for any lost or stolen corporate device. For

personal BYOD devices enrolled in MAM, only corporate data containers are wiped; personal data is not touched.

15.1 Remote Work Security

Employees working remotely must adhere to the following additional requirements:

- Corporate VPN must be connected when accessing any internal network resource (on-premises servers, internal applications not accessible via Zero Trust Network Access)
- Wi-Fi: Only trusted, password-protected home or office networks are permitted; public Wi-Fi must only be used with VPN active
- Physical security: Screens must not be viewable by non-authorized individuals in public spaces; privacy screens are issued on request
- Family members and visitors must not have access to unlocked corporate devices at any time
- Printing of CONFIDENTIAL or RESTRICTED documents at home requires prior Security Manager approval; such documents must be shredded immediately after use and not retained at home

Remote session inactivity auto-lock is enforced at 5 minutes via MDM policy.

16. Email Security

16.1 Email Security Controls

Corporate email is provided through Microsoft 365 with the following security controls enforced:

- SPF, DKIM, and DMARC records configured and enforced for the coreaxistech.com domain; incoming email from domains without valid SPF and DKIM is quarantined
- Microsoft Defender for Office 365 (Plan 2) is enabled providing: Safe Links (URL detonation and real-time protection), Safe Attachments (sandboxed attachment analysis), anti-phishing policies targeting impersonation attacks, and Zero-Hour Auto Purge (ZAP) to retroactively remove malicious messages
- External email is tagged with a banner indicating the message originated outside CoreAxis
- Automatic email forwarding to external addresses is blocked by policy
- Encrypted email (S/MIME or Microsoft Purview Message Encryption) is required for email containing RESTRICTED data

Employees must not use personal email accounts for any CoreAxis business communications.

16.2 Phishing Awareness

Phishing remains the leading initial access vector across the threat landscape. All employees receive phishing simulation training quarterly. Failure to identify

simulated phishing attempts triggers mandatory remediation training within five business days.

Employees must report suspected phishing messages using the "Report Message" button in Outlook or by forwarding to security@coreaxistech.com. Reported phishing messages are investigated by the SOC within four business hours during standard working hours.

Employees must never click links, open attachments, or provide credentials in response to unsolicited emails — even if the sender appears to be a CoreAxis executive. The CISO and executive team will never request credentials or sensitive information via email.

17. Network Security Standards

17.1 Network Architecture

CoreAxis office networks are segmented into security zones with controlled inter-zone communication. Network segmentation is enforced at both physical (VLAN) and logical (firewall policy) layers.

Defined network zones:

- Corporate LAN: Standard workstation and office infrastructure
- Restricted Zone: Servers, data storage, development build systems
- Guest Network: Visitor and personal device network with internet-only access;

no access to Corporate LAN or Restricted Zone

- DMZ: Public-facing services with controlled ingress/egress

Traffic between zones requires explicit allow rules. Default-deny posture is enforced on all inter-zone firewalls. Rule changes require Security Engineer approval and must be documented with business justification, owner, and review date. Stale firewall rules with no associated active business purpose are removed quarterly.

Network Intrusion Detection Systems (NIDS) are deployed at zone boundaries and generate alerts that feed into the SIEM platform.

18. Firewall Management

18.1 Firewall Policy Standards

Perimeter and inter-zone firewalls are managed by Security Engineers. CoreAxis deploys Palo Alto Networks Next-Generation Firewalls (NGFWs) at the network perimeter and Cisco Firewalls for internal zone segmentation. Firewall configurations are version-controlled in Git with peer review required for all changes.

Firewall rule standards:

- All rules must have a documented owner, creation date, business justification, and review date

- Rules must be specific: source address, destination address, and protocol/port must all be explicitly defined; "any" as a source or destination requires Security Manager approval
- Rules permitting inbound access from the internet are classified as high-risk and require CISO review
- Application layer inspection (App-ID on Palo Alto) is enabled for all outbound internet traffic
- SSL/TLS inspection is enabled for outbound traffic to detect encrypted threats
- Firewall rules are audited quarterly; rules not revalidated within 90 days are automatically scheduled for removal

Emergency firewall rule changes follow the incident response emergency change procedure with post-incident documentation required within 24 hours.

19. VPN Security

19.1 VPN Standards and Requirements

CoreAxis provides corporate VPN access for remote employees connecting to internal network resources. VPN access requires: a valid corporate identity authenticated through Entra ID; MFA verification; and an endpoint compliance check confirming that the connecting device meets the managed device security baseline.

Approved VPN protocols: WireGuard (preferred); IKEv2/IPsec. PPTP and L2TP/IPsec are deprecated and not permitted.

Split tunneling configuration:

- Traffic destined for internal network resources routes through the VPN tunnel
- General internet traffic is permitted to route directly (split tunnel)
- Traffic to cloud service provider management planes (AWS, Azure) always routes through the VPN tunnel

VPN access logs are retained for 12 months and reviewed by the SOC for anomalous connection patterns (unusual geographic origins, excessive connection volumes, after-hours access). Remote access sessions exceeding 12 hours of continuous connection trigger an automatic review alert.

20. Cloud Security Guidelines

20.1 Cloud Security Architecture

CoreAxis cloud environments span AWS (primary) and Azure (secondary). All cloud deployments must conform to defined security baselines before moving to production. Security reviews are mandatory for new cloud architectures and for changes that modify network exposure, IAM permissions, or data storage configurations.

AWS Security Controls:

- AWS GuardDuty enabled in all accounts and regions; findings stream to the central SIEM
- AWS Security Hub enabled with CIS AWS Foundations Benchmark and AWS Foundational Security Best Practices standards activated
- AWS Config enabled for configuration drift detection; non-compliant resources trigger automated alerts
- CloudTrail logging enabled in all regions with log files centralized to a dedicated security logging S3 bucket with write-once (WORM) configuration
- S3 Block Public Access enabled at the account level; any exception requires CISO approval with documented justification
- VPC Flow Logs enabled for all production VPCs

Azure Security Controls:

- Microsoft Defender for Cloud enabled across all subscriptions at Standard tier
- Azure Monitor and Azure Security Center alerts integrated into the SIEM
- Azure Policy assigned to enforce security baseline requirements (e.g., require encryption, deny public IP assignments to sensitive resources)
- Azure Key Vault used for all key and secret management

20.2 Cloud Security Baseline Requirements

Before any cloud resource is promoted to production, it must pass a security checklist review conducted by the Cloud Security Engineer. Mandatory checks include:

Compute (EC2, Azure VMs): Patched to current approved AMI/image; endpoint protection agent installed; no public IP without Security Manager approval; IAM instance profile with least-privilege permissions.

Storage (S3, Azure Blob): Encryption at rest enabled; public access blocked; access logging enabled; versioning enabled for CONFIDENTIAL data buckets; bucket policies restricted to specific principals.

Databases (RDS, Aurora, Azure SQL): Encryption at rest enabled; automated backups enabled with appropriate retention; database not publicly accessible; authentication via IAM database authentication or managed identity preferred over static credentials.

Serverless (Lambda, Azure Functions): IAM execution role with minimum permissions; no hardcoded credentials in function code; environment variables containing secrets injected from Secrets Manager or Key Vault; VPC integration required for functions accessing private resources.

Containers (ECS, EKS, AKS): Images scanned for vulnerabilities prior to deployment; base images pulled from approved registries only; privileged container mode disabled; Pod Security Standards (Kubernetes) enforced.

21. Application Security

21.1 Application Security Standards

All applications developed by CoreAxis must be designed, built, and deployed in accordance with the Application Security standards defined in this section. These

standards apply to internal tools, client-facing products, AI applications, and any APIs exposed externally or internally.

The CoreAxis application security program addresses the OWASP Top 10 as the minimum baseline for web application vulnerability coverage. Applications must be assessed against all applicable OWASP Top 10 categories before production deployment.

Security requirements are defined in the threat model for each application and are treated as functional requirements, not post-development additions. Security defects found during production are triaged using the same severity classification as security incidents.

Security sign-off by the DevSecOps team is a prerequisite for production deployment of any new application or major version release.

21.2 Secure Coding Requirements

Input validation: All user-supplied input must be validated on the server side. Client-side validation may supplement but never replace server-side controls. Validation must enforce type, length, format, and range. Reject, do not sanitize, unless sanitization is the documented and intended behavior (e.g., HTML sanitization for rich text fields).

Output encoding: All data rendered in HTML must be properly HTML-encoded to prevent XSS. Output encoding must be context-appropriate: HTML encoding for HTML context, JavaScript encoding for JS context, URL encoding for URL parameters.

SQL injection prevention: All database interactions must use parameterized queries or prepared statements. Dynamic SQL construction using string concatenation is prohibited. ORM usage is preferred; raw SQL must be reviewed by a Security Engineer.

CSRF protection: All state-changing operations (POST, PUT, PATCH, DELETE) must include CSRF token validation. SameSite cookie attribute must be set to Lax or Strict for all session cookies.

Authentication: Session tokens must be generated using cryptographically secure random number generators. Session invalidation must occur on logout. Session fixation attacks must be prevented by issuing new session tokens after authentication.

22. Secure Software Development (SSDLC)

22.1 SSDLC Process

CoreAxis follows a Secure Software Development Lifecycle (SSDLC) that integrates security activities at each phase of software development. Security is not a post-development gate; it is an ongoing activity that begins at requirements gathering and continues through deployment and operations.

SSDLC phases and security activities:

Requirements phase: Security requirements are defined alongside functional requirements. The security team reviews high-risk features and new systems for threat modeling requirements.

Design phase: Threat modeling is conducted for all new applications and significant feature changes. The STRIDE methodology is used. Data flow diagrams are produced and reviewed for trust boundary violations.

Development phase: Developers follow secure coding standards. Code is written against the security requirements defined in the threat model. Security champions embedded in engineering teams provide peer review guidance.

Testing phase: Static Application Security Testing (SAST) runs on every pull request via SonarQube and GitHub Advanced Security CodeQL. Dynamic Application Security Testing (DAST) is conducted on staging environments prior to major releases. Third-party dependency scanning runs via OWASP Dependency-Check.

Deployment phase: Infrastructure security configurations are validated. Secrets are confirmed to be managed via Secrets Manager, not hardcoded. Security sign-off from DevSecOps is obtained before release.

Post-deployment: Applications are monitored for security events. Vulnerability disclosures are tracked and remediated within defined SLAs.

23. DevSecOps Standards

23.1 CI/CD Security Gates

All code changes to CoreAxis repositories must pass mandatory security gates before merging to the main branch. These gates are enforced as required status checks in GitHub Enterprise and cannot be bypassed without explicit CISO approval.

Mandatory security gates:

1. Secret scanning (GitHub Advanced Security): Detects hardcoded credentials, tokens, and keys in code commits. Any detected secret blocks the merge; the credential must be revoked and removed before the pipeline can proceed.
2. SAST (SonarQube + CodeQL): Identifies security vulnerabilities in code. Critical and High severity findings block merge. Medium and Low findings are recorded in the security backlog.
3. Dependency scanning (OWASP Dependency-Check, GitHub Dependabot): Identifies known vulnerabilities (CVEs) in third-party libraries. Critical CVEs block deployment to production.
4. Container image scanning: All Docker images are scanned before being pushed to the container registry. Images with critical or high CVEs are not permitted in production without a documented exception and compensating control.
5. Infrastructure as Code scanning (Checkov, tfsec): Terraform and CloudFormation templates are scanned for security misconfigurations before infrastructure changes are applied.

23.2 Container and Kubernetes Security

Container security standards for CoreAxis deployments:

Base images: Only approved base images from the CoreAxis internal registry are permitted. Base images are updated monthly or within 72 hours of a critical CVE affecting the base OS layer. Builds using unofficial or unvetted base images are blocked by CI policy.

Build security: Dockerfiles must not contain hardcoded credentials; all secrets are injected at runtime via environment variables sourced from Secrets Manager. Multi-stage builds are used to minimize the attack surface of production images. Root user execution in containers is prohibited; all containers must run as a non-root user.

Kubernetes security: Pod Security Standards (Restricted profile) are enforced in production namespaces. Network policies define allowed inter-pod communication; all other traffic is denied by default. RBAC is configured such that each service account has only the Kubernetes permissions required for its function. Kubernetes Secrets are encrypted at rest using etcd encryption. The Kubernetes API server is not publicly accessible; access is restricted to VPN or private network only.

Registry security: Images are signed and signature verification is enforced at deployment. Unsigned images are rejected by the admission controller.

24. API Security

24.1 API Security Standards

All APIs exposed by CoreAxis — whether internal service-to-service, client-facing, or AI model inference endpoints — must conform to the following security standards.

Authentication: All API endpoints must require authentication. Supported authentication methods:

- OAuth 2.0 with JWT bearer tokens (preferred for user-delegated access)
- API keys for service-to-service communication (stored in Secrets Manager, never in code)
- mTLS for high-trust internal service mesh communication

Authorization: Authorization must be enforced at the API layer, not delegated solely to the client. Each endpoint must enforce the minimum required permission scope. Object-level authorization must be validated to prevent Broken Object Level Authorization (BOLA) — a caller must never be able to access or modify another user's resources by manipulating identifiers.

Rate limiting: All public APIs must implement rate limiting to prevent abuse and resource exhaustion. Rate limit thresholds must be defined in the threat model. Rate limit violations must be logged and alert thresholds defined in the SIEM.

API versioning: Breaking changes must be versioned. Deprecated API versions must have a defined sunset date communicated to consumers with a minimum 90-day notice period.

API documentation: API contracts must be maintained in OpenAPI specification format in the source repository. Documentation must accurately reflect the implemented API including all security requirements.

25. Secret Management

25.1 Secrets Management Standards

A "secret" is any credential, token, key, or certificate that grants access to a protected resource. This includes API keys, database passwords, private keys, OAuth tokens, and application credentials.

Approved secrets management platforms:

- AWS Secrets Manager: Primary platform for secrets consumed by AWS workloads
- Azure Key Vault: Primary platform for secrets consumed by Azure workloads
- HashiCorp Vault: Available for multi-cloud or on-premises secret management requirements

Prohibited secret storage locations:

- Source code or Git repositories (enforced by automated scanning)

- Container images or Docker layers
- Plain-text configuration files checked into version control
- Environment variable files (.env files) in source repositories
- Spreadsheets, wikis, ticketing systems, or email
- CI/CD pipeline configuration files (secrets must be injected from approved managers at runtime)

All secrets must have:

- A documented owner
- A defined expiration or rotation schedule
- Access logging enabled on the secrets management platform
- Rotation automation implemented where the application supports it

26. Vulnerability Management

26.1 Vulnerability Management Program

CoreAxis operates a continuous vulnerability management program that identifies, classifies, prioritizes, and remediates security vulnerabilities across all technology assets.

Vulnerability scanning cadence:

- Internal network vulnerability scanning: Weekly
- Cloud infrastructure scanning: Continuous (AWS Security Hub, Microsoft

Defender for Cloud)

- Application DAST scanning: Pre-release (major releases) and monthly (production)
- Container image scanning: Every build and daily for images in production
- External penetration testing: Annual, conducted by an approved third-party security firm

Vulnerability remediation SLAs based on CVSS score:

- Critical (CVSS 9.0–10.0): Remediation or compensating control within 72 hours
- High (CVSS 7.0–8.9): Remediation within 14 days
- Medium (CVSS 4.0–6.9): Remediation within 60 days
- Low (CVSS 0.1–3.9): Remediation within 180 days or accepted risk with documentation

Vulnerabilities that cannot be remediated within the defined SLA must be escalated to the Security Manager for risk acceptance with documented compensating controls.

27. Patch Management

27.1 Patch Management Standards

Patch management at CoreAxis covers operating systems, middleware, application frameworks, third-party libraries, firmware, and network device

software. The IT department owns endpoint patching; the Security Engineering team owns server and infrastructure patching; DevSecOps owns library and dependency patching in application code.

Patching cadence:

- Critical security patches: Deploy within 72 hours of release (after expedited validation testing)
- High security patches: Deploy within 14 days
- Routine patches (OS, application): Monthly patch cycle with deployment in the first two weeks of each month following a defined change management process

Patch validation:

- Patches are tested in the staging environment before production deployment
- Critical patches may bypass staging when the risk of delay exceeds the risk of expedited deployment; this exception requires Security Manager approval
- Patch deployment success rates are tracked as a KPI; any device or system that has not received the current patch within the SLA triggers an alert to the Security Manager

End-of-life software: Software that has reached end-of-life and no longer receives security patches must be upgraded or decommissioned. Running EOL software in production requires a documented risk acceptance with a CISO-approved remediation timeline.

28. Security Logging and Monitoring

28.1 Logging Standards

Security-relevant logs must be collected from all critical systems, stored centrally, and retained for the minimum periods defined below. Log integrity is protected by streaming logs to the SIEM in near-real-time; local log modification does not affect the centralized copy.

Log sources required for centralized collection:

- Entra ID / Active Directory: All authentication events, MFA events, Conditional Access policy decisions, privileged role activations
- Endpoint (Microsoft Defender for Endpoint / CrowdStrike Falcon): Process execution, network connections, file modification events, threat detections
- AWS CloudTrail: All API calls in all regions
- AWS GuardDuty, Security Hub: All findings
- Azure Monitor / Defender for Cloud: All alerts and policy violations
- Firewall (Palo Alto, Cisco): All allowed and denied traffic; threat log events
- VPN: Connection events, authentication events
- Web Application Firewall (WAF): All request logs, blocked request events
- Application logs: Authentication events, authorization failures, sensitive data access events

Log retention:

- Security logs: Minimum 12 months online (searchable); 7 years archive (cold

storage)

- CloudTrail logs: 12 months online; 7 years archive (aligned with regulatory requirements)
- Application logs: 12 months minimum

28.2 SIEM and Monitoring

Splunk is the primary SIEM platform for the CoreAxis Security Operations Center. Microsoft Sentinel provides cloud-native SIEM capabilities for Azure-sourced events and serves as a secondary detection platform. The ELK Stack (Elasticsearch, Logstash, Kibana) is used for application log aggregation and analysis.

Grafana and Prometheus are used for infrastructure metrics monitoring with security-relevant alerting (e.g., anomalous CPU spikes that may indicate cryptomining; unusual outbound data volumes indicative of exfiltration).

SIEM tuning:

- Detection rules are reviewed and updated monthly based on emerging threat intelligence
- Alert thresholds are reviewed quarterly to maintain a signal-to-noise ratio that supports effective SOC operations
- All critical and high-severity alerts must be investigated within defined SLA thresholds (see Incident Response section)
- False positive rate for any single detection rule must not exceed 10% before the rule is retuned or disabled

Threat hunting:

- Proactive threat hunting exercises are conducted quarterly by the Security Engineering team using hypothesis-based hunting methodologies
- Hunt findings are reviewed against existing detection rules; new detections are created to automate future identification of confirmed threat patterns

29. Security Incident Response

29.1 Incident Classification

A security incident is any event that has the potential to, or has confirmed, adversely affected the confidentiality, integrity, or availability of CoreAxis information assets or those of our clients.

Severity classification:

Severity 1 — Critical: Confirmed breach of RESTRICTED data; active ransomware or destructive attack; confirmed APT activity in production systems; compromise of privileged accounts. Response target: Immediate (within 15 minutes of confirmation). CISO and Security Manager must be notified immediately.

Severity 2 — High: Suspected breach requiring investigation; confirmed malware infection on a production server; unauthorized privileged access attempt; DoS

impacting production services. Response target: Within 2 hours of confirmation. The Security Manager must be notified within 30 minutes.

Severity 3 — Medium: Malware on a corporate endpoint (contained); policy violation with security implications; failed intrusion attempt with indicators of compromise; phishing email delivered to users. Response target: Within 24 hours. SOC responds with Security Manager escalation if needed.

Severity 4 — Low: Isolated policy violation; spam or low-confidence phishing simulation failure; single failed brute-force attempt. Response target: Within 72 hours. SOC resolves with documentation.

29.2 Incident Response Workflow

The CoreAxis incident response process follows the PICERL framework: Preparation, Identification, Containment, Eradication, Recovery, and Lessons Learned.

Preparation: Incident response playbooks maintained for all known incident types (ransomware, data breach, phishing, insider threat, cloud compromise, AI model tampering). Playbooks reviewed quarterly and tested via tabletop exercises bi-annually. Contact trees for escalation maintained and tested.

Identification: SOC analyst receives alert or report. Analyst triages to determine if the event constitutes an incident. Incident ticket created in the ITSM system. Severity assigned. Responders mobilized per severity tier.

Containment: Immediate containment actions executed per playbook. Priority is to limit damage scope while preserving evidence. Containment actions

documented with timestamp and operator. Network isolation, account suspension, or cloud resource quarantine applied as appropriate.

Eradication: Root cause identified. Malware, unauthorized access paths, and attacker persistence mechanisms removed. Affected systems reimaged or restored from known-good backups where required.

Recovery: Affected systems restored to production after security validation. Monitoring enhanced for post-incident period (minimum 30 days). Business units notified of restoration status.

Lessons Learned: Post-Incident Review (PIR) conducted within five business days for Severity 1 and Severity 2 incidents. PIR output: documented timeline, root cause, control gaps identified, remediation actions with owners and deadlines.

29.3 Evidence Collection and Chain of Custody

For all Severity 1 and Severity 2 incidents, digital evidence must be collected and preserved in accordance with chain of custody procedures to support potential legal proceedings, regulatory reporting, or forensic analysis.

Evidence collection requirements:

- Memory captures from affected systems before any remediation actions that would alter volatile data
- Disk images using write-blocking tools where forensically necessary
- Log exports from SIEM covering the investigation window plus 48 hours before the earliest identified indicator
- Network capture (PCAP) where available and relevant

- Screenshots and screen recordings of attacker activity observed in security tooling

Chain of custody requirements:

- All evidence items logged with: identifier, description, collection time, collector name, and storage location
- Evidence stored in write-protected, integrity-hashed storage containers
- Access to evidence restricted to the incident response team and legal counsel
- Chain of custody log maintained for all access events

Evidence retention: Minimum 12 months from incident closure; longer periods required when legal action is ongoing or anticipated.

30. Malware Protection

30.1 Malware Protection Standards

Malware protection at CoreAxis is implemented in layers across the endpoint, network, email, and application tiers. No single control is relied upon in isolation.

Endpoint layer: Microsoft Defender for Endpoint (Windows) and CrowdStrike Falcon (macOS) provide real-time malware detection and response. Both platforms operate in active protection mode with behavioral detection enabled. EDR agents must not be disabled by end users; attempted disablement generates a high-priority alert in the SIEM.

Email layer: Microsoft Defender for Office 365 Safe Attachments detonates all email attachments in a sandboxed environment before delivery. Macro-enabled Office documents from external sources are blocked by default.

Network layer: Palo Alto NGFW threat prevention profiles block known malware command-and-control (C2) communications and malicious file downloads. DNS security (Palo Alto DNS Security or similar) blocks resolution of known malicious domains.

Web layer: Web content filtering blocks access to known malicious URLs and categories with high malware delivery rates.

Response to malware detection:

- Endpoint with confirmed malware is immediately isolated from the network
- SOC investigates scope and lateral movement
- Remediation via EDR or reimaging depending on severity and confidence of clean state
- Threat intelligence extracted from the malware sample and added to detection signatures

31. Backup Security

31.1 Backup Standards

Secure backups are a critical component of the CoreAxis resilience posture.

Backups protect against data loss, ransomware, and accidental deletion.

Backup requirements for CONFIDENTIAL and RESTRICTED data systems:

- Recovery Point Objective (RPO): Maximum 24 hours for standard systems; 4 hours for critical production systems
- Recovery Time Objective (RTO): Maximum 8 hours for critical systems; 24 hours for non-critical systems
- Backup frequency: At minimum daily incremental with weekly full backup for standard systems; continuous replication for critical databases
- Backup encryption: All backups must be encrypted at rest using AES-256 and in transit using TLS 1.2+
- Backup immutability: Production backups are stored in write-once, tamper-evident storage (AWS S3 Object Lock in Compliance mode; Azure Blob Storage with immutable policies) to prevent ransomware encryption or deletion of backup data
- Offsite storage: Backup copies must be maintained in a geographically separate region (cross-region replication in AWS/Azure)
- Backup testing: Restore tests conducted monthly for critical systems; quarterly for non-critical systems. Test results documented and any failures treated as high-priority incidents.

Access to backup systems is restricted to authorized IT and Security personnel. Backup administrative credentials are stored in the secrets management platform.

32. Disaster Recovery Support

32.1 Security's Role in Disaster Recovery

The Information Security department supports the broader Disaster Recovery (DR) program owned by IT and Operations. Security's role in DR encompasses ensuring that security controls are maintained or rapidly restored during a disaster scenario, and that recovery processes do not introduce new vulnerabilities.

Security contributions to DR:

- Review and approval of DR architectures to ensure security controls are replicated in DR environments
- Maintenance of security credentials and configurations required for DR activation (stored in the secrets management platform, geographically replicated)
- Participation in DR tests to validate that security monitoring and controls are operational in the recovered environment
- Assurance that DR processes do not involve transferring sensitive data through insecure channels

Security controls must be verified as operational before the DR environment is declared production-ready. A SOC monitoring capability must be active in the DR environment before business systems are restored to it.

33. Business Continuity Support

33.1 Security and Business Continuity

The Information Security department maintains security operational continuity planning independent of the broader Business Continuity Plan (BCP). Security operations must continue or rapidly resume during scenarios that impact physical office access, IT infrastructure, or key personnel.

Security continuity provisions:

- SIEM and SOC monitoring are cloud-hosted and accessible remotely; monitoring does not depend on physical office access
- Incident response capability is maintained during BCP events; on-call rotations are preserved with contact tree escalation procedures for key personnel unavailability
- Security tooling licenses and access credentials are documented and accessible to at least two senior security personnel
- Security documentation (playbooks, runbooks, contact trees) is stored in geographically replicated cloud storage accessible to authorized personnel from

any location

- VPN access is available for all security personnel to enable remote operation

Business continuity scenarios are reviewed annually by the Security Manager in coordination with the BCP owner.

34. AI Security Standards

AI Model Security

CoreAxis develops, trains, fine-tunes, and deploys AI models including Large Language Models, computer vision systems, and intelligent automation components. AI model assets require dedicated security controls that address threats specific to machine learning systems.

Model weight protection:

- Trained model weights are classified as RESTRICTED
- Model weights are stored in encrypted object storage (AWS S3 with SSE-KMS) with access restricted to the AI/ML team and authorized DevOps personnel
- Model weights are never committed to version control repositories
- Model weight access is logged; anomalous access patterns (unusual volumes, off-hours access) trigger SOC alerts

Dataset security:

- Training datasets containing PII or client data are classified RESTRICTED and

subject to all data handling standards for that classification

- Datasets must not be stored in developer workstations or shared network drives; approved storage is cloud-hosted with access control
- Dataset access is logged and reviewed quarterly

Model version control:

- All model versions are tracked in a model registry with metadata (training date, data provenance, evaluation metrics)
- Production model deployments require sign-off from both the AI/ML team lead and the Security Engineer
- Model rollback procedures are documented and tested annually

34.1 AI Access Control and API Security

AI model inference endpoints — whether internal or externally exposed — are secured as high-value API assets.

Authentication: All AI API endpoints require strong authentication.

External-facing AI APIs use OAuth 2.0 with JWT bearer tokens or API key authentication with rate limiting enforced. Internal AI microservices use mTLS for service-to-service authentication.

Authorization: AI model access is role-controlled. Only authorized services and users may invoke specific model endpoints. Unrestricted inference access is not permitted in production.

Rate limiting: AI inference endpoints are protected by rate limiting to prevent abuse (cost abuse, model extraction via repeated queries). Rate limits are defined per client ID and monitored in real-time.

Input/output logging: All AI inference requests and responses are logged for audit and security analysis purposes. Logs are reviewed for anomalous patterns indicative of prompt injection or model extraction attacks. Logging of sensitive PII within inference payloads must be governed by appropriate data retention and access controls.

35. LLM Security Guidelines

35.1 Prompt Injection Prevention

Prompt injection is a class of attack specific to LLM-based systems where malicious user input manipulates the model's behavior by overriding or circumventing the system prompt or developer instructions. CoreAxis LLM applications must implement controls to detect and prevent prompt injection.

Preventive controls:

- System prompts must be clearly separated from user-supplied content in the prompt construction logic; they must not be combined in a way that allows user input to override system instructions
- Input validation must reject or sanitize inputs that contain known injection patterns (e.g., "Ignore previous instructions", "You are now in developer mode")
- Prompt templates must be reviewed by a Security Engineer before deployment; changes to system prompts for production LLM applications require a security review

- Structured output formats (JSON schema enforcement, Pydantic validation) reduce the attack surface for instruction injection in the output path
- LLM outputs that affect downstream system actions (e.g., tool calls, database writes, API calls via LangChain or LlamaIndex function calling) must go through an authorization layer before execution; the LLM output alone is never sufficient authorization for a sensitive action

Detection controls:

- Anomalous LLM output patterns (unexpected role changes, attempts to output system prompt contents, instructions to call unauthorized tools) must trigger alerts
- Monitoring of LLM outputs is conducted via a dedicated output validation layer before results are returned to users or passed to downstream systems

35.2 Data Poisoning and Hallucination Risk

Data poisoning: Training data sourced from external or user-generated sources poses a risk of data poisoning, where adversarially crafted data is included in the training set to manipulate model behavior or introduce backdoors.

Controls against data poisoning:

- Training data must be sourced from documented, trusted sources with clear data provenance
- External data used for training undergoes a review process to identify anomalous or adversarial patterns before inclusion
- Fine-tuning datasets from clients must be reviewed by the AI/ML team and the Security Engineer before use
- Training pipelines are isolated from production environments; training infrastructure is a separate environment with restricted access

Hallucination risk management: LLMs produce confident-sounding outputs that may be factually incorrect. In enterprise contexts where LLM outputs influence business decisions, hallucination poses operational and reputational risks.

Controls for hallucination risk:

- RAG architectures are preferred over pure generative responses for factual queries, as they ground outputs in retrieved, verifiable documents
- Output validation layers check for consistency of LLM responses against known-good reference data where applicable
- LLM-generated content that will be used in regulated contexts (legal, financial, medical) must be reviewed by a human subject matter expert before use
- User interfaces displaying LLM outputs must include appropriate disclaimers about the nature of AI-generated content

36. RAG Security Guidelines

36.1 RAG Pipeline Security

Retrieval-Augmented Generation (RAG) systems combine document retrieval with language model generation. CoreAxis develops RAG products using LangChain, LlamaIndex, ChromaDB, and FAISS. These systems introduce security considerations at the retrieval, embedding, and generation stages.

Document ingestion security:

- Documents ingested into the RAG pipeline must be authorized for that specific knowledge base; ingestion of unauthorized documents (e.g., confidential client data into a shared knowledge base) must be prevented
- Document ingestion pipelines must validate the classification of source documents against the permitted classification level for the target knowledge base
- Ingestion processes run with least-privilege credentials; the ingestion service account must not have write access to the vector database index used for production serving

Embedding security:

- Embedding models and vector databases (ChromaDB, FAISS) are internal components; they must not be exposed to external network access without authentication and authorization controls
- Embedding vectors may encode sensitive information from source documents; they must be stored with access controls equivalent to the highest-classified document they were derived from
- Embedding model versions are tracked; changes to the embedding model require re-indexing and security review

Retrieval security:

- Retrieval queries must enforce document-level access control; a user's query must only retrieve documents they are authorized to access
- Multi-tenant RAG deployments must enforce strict tenant isolation at the vector database query level; cross-tenant data leakage via retrieval is a critical vulnerability

- Retrieval results passed to the LLM must be sanitized to remove metadata that could enable prompt injection through document content

36.2 Vector Database Protection

Vector databases (ChromaDB, FAISS, pgvector) are specialized data stores that index embedding vectors derived from source documents. They present unique security considerations:

Access control: Vector database access must be restricted to authorized application services via API authentication. Direct human access to production vector databases requires Security Manager approval and must be logged.

Data sensitivity: Embedding vectors encode semantic information from source documents. Membership inference attacks can extract information about the original training data from embeddings. Vector databases containing embeddings derived from CONFIDENTIAL or RESTRICTED data must be treated with equivalent data sensitivity classifications.

Index integrity: The integrity of the vector index is critical to RAG output quality. Unauthorized modification of the index (index poisoning) can cause the RAG system to retrieve attacker-controlled content. Write access to the production vector index is restricted to the authorized ingestion pipeline service account only.

Backup and recovery: Vector indices must be backed up with the same frequency and security standards as other CONFIDENTIAL data stores. Index reconstruction from source documents must be tested annually to validate disaster recovery capability.

37. Client Data Protection

37.1 Client Data Obligations

CoreAxis processes client data as part of delivering enterprise AI software and services. Our obligations to protect client data are defined in contractual Data Processing Agreements (DPAs) and the applicable data protection regulations for each client's jurisdiction.

General client data protection principles:

- Client data is processed only for the purposes specified in the DPA; purpose limitation is strictly enforced
- Client data is not used to train CoreAxis AI models without explicit written consent from the client
- Client data environments are logically isolated from other client environments and from CoreAxis internal data systems
- Access to client data is restricted to CoreAxis employees with a documented, approved business need for that specific client engagement
- All client data access events are logged and available for client audit upon request

Data residency: Client data is stored in the geographic region specified in the contract. Cross-region data transfer requires explicit client approval and DPA amendment. CoreAxis does not transfer client data outside the contractually specified regions without consent.

Data breach notification: In the event of a confirmed breach affecting client data, CoreAxis must notify the affected client(s) within 72 hours of confirmation, in accordance with contractual obligations and applicable law. The CISO is responsible for breach notification decisions and coordination with Legal.

38. Third-Party Vendor Security

38.1 Vendor Security Assessment Program

Any third party that has access to CoreAxis systems, data, or infrastructure is subject to a security assessment before contract award and on an ongoing basis. The Security Manager owns the vendor security assessment program.

Pre-contract assessment:

- All new vendors classified as handling CONFIDENTIAL or RESTRICTED data, or with logical access to CoreAxis systems, require a completed security questionnaire
- Vendors must demonstrate compliance with a recognized security framework (ISO/IEC 27001 certification, SOC 2 Type II report, or equivalent)
- High-risk vendors (those with privileged or broad system access, or who process large volumes of client data) require an on-site or virtual assessment by a CoreAxis Security Engineer

Ongoing monitoring:

- Annual security review for all Tier 1 (critical) vendors
- Bi-annual security review for Tier 2 vendors
- Any vendor security incident that may affect CoreAxis or client data triggers an immediate ad-hoc review

Contractual requirements:

- All vendor contracts must include: security and data protection obligations; the right to audit; incident notification requirements (72 hours); data return and deletion obligations upon contract termination; and subprocessor disclosure requirements

Vendor access management:

- Third-party access to CoreAxis systems is provided through dedicated vendor accounts with MFA required
- Vendor sessions for privileged operations are recorded via PAM tooling
- Vendor access is time-limited and deactivated immediately upon contract expiration or termination

39. Compliance Requirements

39.1 Regulatory and Framework Compliance

CoreAxis Technologies maintains compliance with the following frameworks and standards:

ISO/IEC 27001: CoreAxis operates an Information Security Management System (ISMS) aligned to ISO/IEC 27001. The ISMS scope, controls, and Statement of Applicability (SoA) are maintained by the Security Manager and reviewed annually. Internal audits are conducted twice per year; the external certification audit is conducted annually by a qualified certification body.

SOC 2 (Type II): CoreAxis prepares for SOC 2 Type II examination covering the Trust Service Criteria applicable to its service offerings (Security; and where applicable, Availability, Confidentiality). Evidence for SOC 2 control activities is collected continuously via automated tooling and documented in the compliance evidence management platform.

Data protection regulations: CoreAxis complies with applicable data protection laws for jurisdictions where clients operate. Legal counsel reviews new client contracts for jurisdictional data protection requirements that may impose additional obligations.

Internal compliance:

- Annual internal compliance audit conducted by the Security team with findings reported to the CISO and Security Governance Committee

- Control deficiencies are tracked in the risk register with remediation timelines
- Compliance metrics are reported to the Board of Directors annually

39.2 Asset Inventory and Log Retention

Asset inventory: CoreAxis maintains a comprehensive inventory of all information assets. The inventory is maintained by the IT department and Security team jointly using an automated asset discovery and management platform. The inventory includes:

- All corporate endpoints with device type, owner, OS version, and compliance status
- All cloud resources (auto-discovered via AWS Config and Azure Resource Graph)
- All software applications with version, license status, and data classification
- All network infrastructure with configuration version and location

Asset inventory is reconciled monthly. Undiscovered or unregistered assets detected by network scanning are investigated and either onboarded to the inventory or removed within 30 days.

Log retention schedule:

- Security event logs (SIEM, EDR, firewall, IAM): 12 months online; 7 years archive
- Application access logs: 12 months online; 3 years archive
- Cloud infrastructure logs (CloudTrail, Azure Monitor): 12 months online; 7 years archive
- Email security logs: 12 months

- Backup and recovery logs: 3 years
- Security incident records: 7 years from closure

All archived logs are stored in write-protected, integrity-hashed storage to prevent tampering.

40. Security Awareness Training

40.1 Security Awareness Program

All CoreAxis employees — including contractors with system access — are required to complete security awareness training. The program is designed and managed by the Information Security department in coordination with HR.

Mandatory training:

- Annual security awareness training: Covers phishing, social engineering, password security, data classification, acceptable use, incident reporting, clean desk, and remote work security. Completion is mandatory; non-completion after the deadline results in access suspension pending completion.
- New hire security orientation: Completed within the first week of employment. Covers onboarding security requirements, how to report incidents, secure remote work basics, and a review of key policies.
- Role-specific training: Engineers and developers complete secure coding training annually. Cloud Engineers complete cloud security training annually. Finance and HR employees complete data protection and social engineering-focused training annually.

Phishing simulation:

- Simulated phishing campaigns are conducted quarterly targeting all employees
- Click-through and credential-submission rates are tracked and reported to department managers
- Employees who fail simulations are enrolled in targeted remediation training within five business days
- Persistent failures (3+ in a 12-month period) are escalated to HR for formal performance discussion

Security champions:

- Each engineering team nominates a Security Champion who receives advanced security training and serves as the security point of contact for their team
- Security Champions attend monthly briefings with the Security team

41. Collaboration with Other Departments

41.1 Security Engagement Model

The Information Security department is a collaborative partner to all CoreAxis departments, not solely an enforcement function. Proactive engagement with other teams reduces risk by integrating security into business activities early, rather than at the remediation stage.

Human Resources: HR and Security partner on: background check standards for new hires; access provisioning and deprovisioning timelines tied to HR events; insider threat awareness; disciplinary processes for policy violations; and the annual security awareness training program.

Software Engineering: Security embeds into the engineering organization through the DevSecOps function, the Security Champion program, and mandatory threat modeling participation. Security signs off on new product releases and significant architecture changes. Engineers may request security consultations at any stage of development.

AI & Machine Learning: Security reviews AI system designs for model security, data pipeline security, and inference endpoint security. Security participates in AI ethics and risk reviews where data sensitivity or misuse risks are relevant. AI model deployments require Security sign-off.

Finance: Security supports Finance through: controls over financial application access; fraud prevention guidance; security reviews of financial system vendors; and controls supporting financial data classified as RESTRICTED.

Information Technology: IT and Security operate in a close partnership. IT owns infrastructure; Security defines requirements and validates compliance. Security reviews all significant IT infrastructure changes, network modifications, and new technology adoptions.

42. Employee Responsibilities

42.1 General Employee Security Obligations

Security is a shared responsibility. While the Information Security department provides controls, governance, and operational capability, every CoreAxis employee contributes to the security of the organization through their daily behavior.

All employees must:

- Complete all mandatory security training within required timelines
- Use strong, unique passwords managed through the enterprise password manager
- Enroll in and maintain MFA for all corporate accounts
- Lock their screen when leaving their workstation
- Report suspected security incidents, phishing emails, or suspicious activity immediately to the SOC (security@coreaxistech.com or the emergency hotline)
- Handle documents and data in accordance with the Information Classification Policy
- Follow the clean desk policy when in the office
- Keep corporate devices up to date with security patches
- Refrain from installing unauthorized software on corporate devices
- Protect physical access credentials (badges, tokens) and never lend them to others
- Not discuss CONFIDENTIAL or RESTRICTED information in public spaces or over unencrypted channels

Employees are never penalized for reporting good-faith security concerns. A security-first culture depends on employees feeling empowered to raise issues without fear.

43. Continuous Security Improvement

43.1 Security Metrics and KPIs

The Information Security department tracks the following key performance indicators and reports them to the Security Governance Committee monthly and to the Board of Directors quarterly.

Operational metrics:

- Mean Time to Detect (MTTD): Average time from threat occurrence to SOC detection
- Mean Time to Respond (MTTR): Average time from alert acknowledgment to containment
- Patch compliance rate: Percentage of critical patches applied within SLA
- Vulnerability remediation rate: Percentage of vulnerabilities remediated within severity-defined SLAs
- MFA enrollment rate: Percentage of accounts with MFA enrolled
- Phishing simulation click rate: Trend across quarterly campaigns

Governance metrics:

- Risk register open items by severity
- Policy exceptions open vs. closed
- Audit finding closure rate
- Vendor assessment completion rate
- Security training completion rate

Program maturity:

- Security Maturity Model assessment score (annual)
- Penetration test finding trends year-over-year
- SOC2 control effectiveness ratings from annual examination

43.2 Security Program Review

The CoreAxis security program undergoes structured review at defined intervals to ensure it remains effective, relevant, and appropriately resourced.

Monthly: Security Governance Committee meeting; SIEM and detection rule tuning; open risk register review; security metrics report.

Quarterly: Access reviews for CONFIDENTIAL and RESTRICTED systems; phishing simulation campaign; threat hunting exercise; vendor security review cycle; security policy review for any domain with significant changes.

Annually: Enterprise-wide risk assessment; full internal security audit (ISO/IEC 27001 scope); penetration testing by external firm; security awareness training program refresh; BCP/DR test with security participation; Security Maturity Model self-assessment; review of all security policies with CISO sign-off.

Event-driven: Post-incident review within five business days for Severity 1 and Severity 2 incidents; security review triggered by significant new technology adoption, regulatory change, or business event (merger, acquisition, new product launch).

44. Appendix

A — Key Contacts

Security Operations Center (SOC): security@coreaxistech.com | Emergency

Hotline: Available internally via the company directory

CISO: ciso@coreaxistech.com

Security Manager: securitymanager@coreaxistech.com

Phishing Report: Forward suspected phishing to phishing-report@coreaxistech.com or use the "Report Message" Outlook button

IT Helpdesk (access issues, device problems): helpdesk@coreaxistech.com |

Internal extension: 100

In a security emergency (active incident, suspected breach), call the Security Emergency Hotline directly — do not rely solely on email.

B — Approved Technology Reference

Identity & Access:

- Microsoft Entra ID — Primary enterprise identity provider
- Active Directory — On-premises domain authentication (synchronized with

Entra ID)

- Okta — SaaS application federation broker
- LDAP — Legacy system integration

Cloud:

- AWS IAM — AWS identity and access management
- AWS GuardDuty — Threat detection service
- AWS Security Hub — Security posture management
- Azure Security Center / Microsoft Defender for Cloud — Azure security posture management

Containers:

- Docker — Container runtime
- Kubernetes (EKS, AKS) — Container orchestration

Monitoring & SIEM:

- Splunk — Primary SIEM platform
- Microsoft Sentinel — Cloud-native SIEM (Azure-sourced events)
- ELK Stack — Application log aggregation
- Grafana / Prometheus — Infrastructure metrics and alerting

Endpoint Protection:

- Microsoft Defender for Endpoint — Windows EDR
- CrowdStrike Falcon — macOS EDR
- BitLocker — Windows full-disk encryption

Network Security:

- Palo Alto Networks NGFW — Perimeter firewall
- Cisco Firewalls — Internal network segmentation

Development Security:

- GitHub Enterprise — Source code management
- GitHub Advanced Security (Secret Scanning, CodeQL) — Code security scanning
- SonarQube — SAST and code quality
- OWASP Dependency-Check / Dependabot — Dependency vulnerability scanning

AI Security:

- LangChain — LLM application framework
- LlamaIndex — RAG framework
- Ollama — Local LLM serving
- ChromaDB — Vector database
- FAISS — Similarity search library

C — Glossary

APT — Advanced Persistent Threat: A prolonged, targeted cyberattack in which an intruder gains access and remains undetected for an extended period.

BOLA — Broken Object Level Authorization: An API vulnerability where a caller can access or modify another user's data by manipulating object identifiers.

CVE — Common Vulnerabilities and Exposures: A standardized identifier for publicly known cybersecurity vulnerabilities.

CVSS — Common Vulnerability Scoring System: A framework for rating the severity of security vulnerabilities.

DPA — Data Processing Agreement: A contractual agreement governing how a data processor handles personal data on behalf of a data controller.

EDR — Endpoint Detection and Response: Security software that continuously monitors endpoints for threat indicators.

IAM — Identity and Access Management: The discipline of managing digital identities and their access to systems and resources.

ISMS — Information Security Management System: A systematic approach to managing sensitive company information to remain secure.

JIT — Just-in-Time: An access model where elevated privileges are granted only for the duration needed for a specific task.

MFA — Multi-Factor Authentication: Authentication requiring two or more verification factors beyond a password.

MTTD — Mean Time to Detect: Average time from a threat event to its detection by the security team.

MTTR — Mean Time to Respond: Average time from alert acknowledgment to containment of the threat.

PAM — Privileged Access Management: A security discipline focused on controlling and monitoring privileged account access.

RAG — Retrieval-Augmented Generation: An AI architecture combining document retrieval with LLM-based text generation.

RBAC — Role-Based Access Control: Access control where permissions are assigned based on a user's organizational role.

SIEM — Security Information and Event Management: Platform that aggregates and analyzes security event data from across the organization.

SOC — Security Operations Center: A team that monitors, detects, and responds to security threats.

SSDLC — Secure Software Development Lifecycle: Integration of security activities throughout the software development process.

Zero Trust — A security model requiring strict identity verification for every person and device, regardless of network location.

D — Document Control

Document Title: CoreAxis Technologies Information Security Department Handbook

Classification: INTERNAL — RESTRICTED

Version: 1.0

Effective Date: June 2026

Review Cycle: Annual (or upon significant policy change)

Document Owner: Chief Information Security Officer

Approved By: CISO — CoreAxis Technologies

Change History:

Version 1.0 — June 2026: Initial release. Covers all 44 sections as defined in the CISO-approved handbook scope.

Distribution: This handbook is distributed to all members of the Information Security department and is available in the internal document management system to employees who require access as part of their role. External distribution is strictly prohibited.

Acknowledgement: All Information Security department employees must formally acknowledge receipt and understanding of this handbook upon joining the department and annually thereafter. Acknowledgement records are maintained by HR.